UNIVERSIDADE DO VALE DO ITAJAÍ • UNIVALI
Escola Politécnica • Ciência da Computação
Segurança de Sistemas Computacionais • 2026/2

TRABALHO 2

Case Prático 2: Modelagem de Ameaças com DFD e STRIDE

Roteiro para as equipes

Mesmas equipes e usando o mesmo laboratório do Trabalho 1

Etapa	O que entregar	Prazo
Etapa 1	Entrega parcial 1: pesquisa, fundamentação e capítulo de contextualização do ambiente (3 a 5 páginas; valida a presença da aula de reposição de 17/10)	AVA, até 23h59 de segunda-feira, 19/10/2026
Etapa 2	Relatório completo de modelagem de ameaças + arquivo-fonte do modelo	AVA, até 23h59 de 28/10/2026
Etapa 3	Apresentação (até 15 min por equipe) e participação nas perguntas	Em aula, 09/11/2026

Prof. Ramicés dos Santos Silva

Sumário

1. Apresentação e objetivos 4
Objetivos de aprendizagem 4
2. Regras gerais 4
3. Visão geral do método 5
4. Etapa 1: pesquisa e contextualização (aula de 17/10) 5
4.1 O que a Etapa 1 deve conter 6
4.2 Perguntas obrigatórias da contextualização 6
4.3 Pontos de partida por laboratório 7
5. Etapa 2: modelagem do sistema e seleção dos fluxos 7
5.1 Notação e convenções do DFD 7
5.2 Níveis de diagrama exigidos 8
5.3 Seleção dos fluxos (mínimo de 4) 9
6. Análise STRIDE de cada fluxo 10
6.1 Revisão rápida: STRIDE e propriedades violadas 10
6.2 STRIDE por elemento 10
6.3 Passo a passo para cada fluxo 10
6.4 Como redigir uma ameaça (evite ameaças genéricas) 11
6.5 Priorização com DREAD 11
6.6 Mitigações e decisão de tratamento 11
6.7 Volume mínimo esperado 12
7. Template de mapeamento 12
7.1 Ficha do fluxo 12
7.2 Matriz STRIDE por elemento do fluxo 13
7.3 Questionário obrigatório por fluxo 13
7.4 Registro de ameaças 15
7.5 Conclusão do fluxo 16
8. Ferramentas sugeridas para o diagrama 16
9. Frameworks e referências de apoio 17
10. Estrutura obrigatória do relatório final (28/10) 18
11. Apresentação (09/11) 18
Critérios observados na nota individual 18
12. Cronograma 19
13. Checklist antes de entregar ..... **Erro! Indicador não definido.**

14. Erros comuns a evitar ..... **Erro! Indicador não definido.**
15. Referências de apoio 19
Apêndice A: exemplo parcialmente preenchido 21

1. Apresentação e objetivos

No Trabalho 1 a equipe olhou para a aplicação **de fora para dentro**: subiu um alvo vulnerável, encontrou falhas e as classificou com OWASP, CWE e CVSS. Neste Trabalho 2 a perspectiva se inverte: a equipe vai olhar o **mesmo sistema de dentro para fora**, como faria um arquiteto ou engenheiro de segurança na fase de projeto, e responder de forma sistemática às quatro perguntas vistas em aula:

1. **O que estamos construindo?** Documentar o sistema com Diagramas de Fluxo de Dados (DFD) e fronteiras de confiança.
2. **O que pode dar errado?** Aplicar o STRIDE, elemento por elemento, nos fluxos escolhidos.
3. **O que vamos fazer a respeito?** Priorizar as ameaças (DREAD) e propor mitigações concretas, conectadas aos controles da Unidade 3.
4. **Fizemos um bom trabalho?** Validar o modelo, registrar premissas e limitações e revisar em pares.

O resultado esperado é um **modelo de ameaças completo** de pelo menos **quatro fluxos** do sistema, documentado com um template padronizado (Seção 7 e Apêndice A) e fundamentado em referências.

Objetivos de aprendizagem

- Pesquisar e descrever com profundidade a arquitetura de um sistema real (tecnologias, componentes, atores, ativos e dados).
- Representar o sistema em DFD de contexto (nível 0) e detalhado (nível 1), com fronteiras de confiança corretas.
- Aplicar o STRIDE de forma sistemática (STRIDE por elemento) e redigir ameaças concretas, não genéricas.
- Priorizar ameaças com critério explícito e justificado (DREAD ou OWASP Risk Rating).
- Propor mitigações rastreáveis a padrões (OWASP ASVS, CWE, Cheat Sheets) e à LGPD.
- Conectar a visão de projeto (modelagem) com a visão de teste (achados do Trabalho 1).
- *Saber ser:* comunicar riscos com clareza, colaborar em equipe e contribuir criticamente com o trabalho dos colegas.

2. Regras gerais

- **Equipes:** as mesmas do Trabalho 1 (até 4 integrantes). Mudanças de composição devem ser comunicadas ao professor na aula do dia 19/10.
- **Laboratório:** cada equipe usa o **mesmo laboratório escolhido no Trabalho 1** (Cenário A: OWASP Juice Shop, ou Cenário B: OWASP WebGoat), na mesma versão de imagem Docker sempre que possível.
- **Foco do trabalho:** modelagem de ameaças. Não é exigida nova exploração; o laboratório serve para **observar** o funcionamento real dos fluxos (DevTools, aba Network, proxy do ZAP ou Burp em modo passivo) e confirmar como os dados trafegam.

- **Fluxos:** no mínimo **4 fluxos** do sistema, analisados por completo com o template proposto. Recomenda-se que **cada integrante seja responsável por pelo menos um fluxo**, o que também orienta a nota individual da apresentação.
- **Autoria e referências:** todo conteúdo externo deve ser citado (ABNT). Trabalhos com sinais de plágio recebem nota zero, conforme o Plano de Ensino.
- **Conduta:** a mesma do Trabalho 1. O ambiente roda apenas localmente (127.0.0.1) e nenhuma ferramenta é apontada para sistemas de terceiros.

3. Visão geral do método

O trabalho segue o processo de modelagem visto na Unidade 2. A tabela abaixo liga cada etapa à pergunta que ela responde e ao entregável correspondente.

Passo	Atividade	Pergunta	Onde aparece
1	Pesquisar e contextualizar o ambiente (arquitetura, atores, ativos, dados, superfície).	O que estamos construindo?	Etapa 1 (19/10) e cap. 3 do relatório
2	Desenhar o DFD nível 0 (contexto) e nível 1 (detalhado), com fronteiras de confiança.	O que estamos construindo?	Cap. 5 do relatório
3	Selecionar e descrever no mínimo 4 fluxos (ficha do fluxo).	O que estamos construindo?	Cap. 6 (uma seção por fluxo)
4	Aplicar STRIDE por elemento em cada fluxo e responder ao questionário.	O que pode dar errado?	Cap. 6
5	Registrar as ameaças, priorizar com DREAD e propor mitigações.	O que vamos fazer?	Cap. 6 e 7
6	Validar o modelo, comparar com o Trabalho 1 e registrar limitações.	Fizemos um bom trabalho?	Cap. 8

4. Etapa 1: pesquisa e contextualização (aula de 17/10)

A aula de reposição do feriado, no **sábado, 17/10/2026**, será dedicada à pesquisa e à redação do capítulo de contextualização do ambiente mapeado. O professor estará à disposição e acompanha as equipes durante a aula. O material produzido é a **entrega parcial 1**, submetida no AVA **até as 23h59 de segunda-feira, 19/10/2026**, e é ela que **valida a presença** na aula de reposição.

Entrega obrigatória e presença

A entrega parcial 1 é obrigatória. A presença da aula de 17/10 será validada pela entrega, conforme a **pesquisa realizada** e as **tarefas executadas e entregues** por cada integrante até **19/10, às 23h59**. Por isso, o documento deve trazer o **quadro de participação** (nome completo e o que cada um pesquisou e produziu). Integrante sem tarefa registrada, ou entrega após o prazo, não tem a presença validada.

4.1 O que a Etapa 1 deve conter

1. **Capa e quadro de participação** (integrante, pesquisa e tarefas realizadas na Etapa 1). É a base para validar a presença.
2. **Fundamentação teórica** (capítulo 2 do relatório), de forma objetiva: modelagem de ameaças no SSDLC e as quatro perguntas; DFD (elementos, níveis e fronteiras de confiança); STRIDE (origem, categorias, propriedades violadas e STRIDE por elemento); priorização de risco (DREAD e/ou OWASP Risk Rating); superfície de ataque.
3. **Contextualização do ambiente** (capítulo 3 do relatório): respostas completas às perguntas C1 a C10 da Seção 4.2.
4. **DFD nível 0 (contexto) preliminar** do sistema, com as entidades externas e as fronteiras de confiança principais.
5. **Lista de fluxos candidatos** (pelo menos 5, dos quais 4 ou mais serão analisados), com uma justificativa curta de cada escolha.
6. **Referências** em ABNT: no mínimo **8 referências**, sendo pelo menos **3 de natureza acadêmica ou normativa** (livros, artigos científicos, normas ISO/NIST, legislação). Documentação oficial do projeto conta como referência técnica.

Extensão: de **3 a 5 páginas**, sem contar capa, quadro de participação, figura do DFD e referências. O texto deve ser **enxuto e robusto**: priorize a contextualização do ambiente (perguntas C1 a C10, que podem ser respondidas em tabelas ou tópicos), com fundamentação concisa, explicação nas palavras da equipe e citações, e não uma colagem de definições. O texto será expandido no relatório final.

4.2 Perguntas obrigatórias da contextualização

O capítulo de contextualização deve responder, com evidências (prints do laboratório, trechos de documentação, arquivos de configuração e referências), às perguntas abaixo.

ID	Pergunta	Fontes sugeridas
C1	O que é o sistema, quem o mantém, qual o seu propósito e qual versão/imagem Docker foi usada (tag e digest)?	Site do projeto, GitHub, Docker Hub
C2	Qual é a arquitetura: front-end, back-end, linguagens, frameworks, bancos de dados, mecanismo de autenticação e sessão, formas de comunicação (REST, WebSocket) e integrações externas?	Documentação oficial, código-fonte, DevTools
C3	Como o laboratório foi implantado (contêiner, rede Docker, portas, host)? Reaproveite e atualize o que foi feito no Trabalho 1.	docker-compose.yml, docker inspect
C4	Quem são os atores e papéis (anônimo, cliente, administrador, sistemas e serviços externos)? Que permissões cada um tem?	Navegação no sistema, documentação
C5	Quais são os ativos: dados e funcionalidades de valor? Quais dados são pessoais ou pessoais sensíveis segundo a LGPD?	Telas, respostas da API, modelo de dados
C6	Quais são os pontos de entrada e a superfície de ataque, organizados nas categorias vistas em aula (rede, interface do usuário, administrativa, integração externa, dados)?	OWASP Attack Surface Analysis Cheat Sheet

ID	Pergunta	Fontes sugeridas
C7	Quais dependências e componentes de terceiros são relevantes para a segurança?	package.json, pom.xml, SBOM
C8	Quais são as principais funcionalidades (inventário de fluxos) e quais a equipe pretende modelar? Por quê?	Seção 5.3 deste roteiro
C9	Quais premissas a equipe adota e o que fica fora do escopo (por exemplo, sistema operacional do host, infraestrutura de nuvem)?	Decisão da equipe
C10	Como os achados do Trabalho 1 se relacionam com essa arquitetura (em que componentes e fluxos eles ocorrem)?	Relatório do Trabalho 1

4.3 Pontos de partida por laboratório

As informações abaixo são apenas ponto de partida e **devem ser confirmadas e aprofundadas** pela equipe na versão que está rodando.

	Cenário A: OWASP Juice Shop	Cenário B: OWASP WebGoat
Natureza	Loja online deliberadamente insegura, em formato de SPA.	Plataforma de ensino com lições guiadas por vulnerabilidade.
Pilha	Front-end Angular (SPA); back-end Node.js com Express expondo API REST; TypeScript/JavaScript.	Aplicação Java com Spring Boot; lições organizadas como módulos; banco embarcado (confirme qual na versão usada).
Dados	Banco principal SQLite (via Sequelize) e armazenamento secundário MarsDB (derivado do MongoDB).	Dados de usuários, progresso das lições e tabelas usadas nos exercícios.
Identidade	Cadastro e login próprios com token; login com conta Google (OAuth 2.0).	Cadastro e login próprios com sessão; algumas lições usam tokens.
Componentes extras	Notificações em tempo real via WebSocket.	WebWolf: aplicação auxiliar que simula a "infraestrutura do atacante" (caixa de e-mail, upload de arquivos, página de captura).
Documentação	help.owasp-juice.shop (livro "Pwning OWASP Juice Shop", capítulo de arquitetura)	github.com/WebGoat/WebGoat e owasp.org/www-project-webgoat

5. Etapa 2: modelagem do sistema e seleção dos fluxos

5.1 Notação e convenções do DFD

Use a notação vista em aula (Shostack, 2014; OWASP Threat Dragon). Todo elemento recebe um **identificador único**, que será usado em todas as tabelas do relatório. Isso garante a rastreabilidade entre diagrama, fichas, registro de ameaças e mitigações.

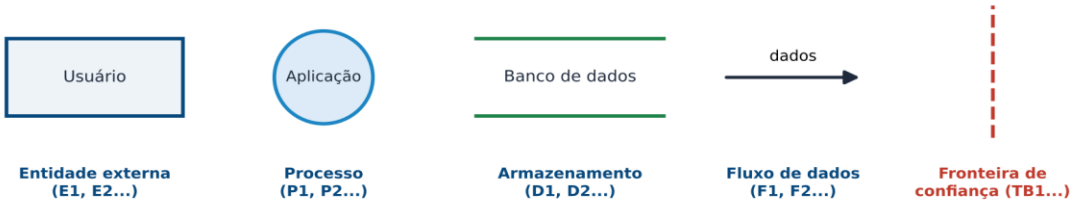


Figura 1. Notação de DFD e convenção de identificadores (elaborado pelo autor).

Elemento	Prefixo	Exemplo	Regra de qualidade
Entidade externa	E	E1 Cliente, E2 Administrador, E3 Google OAuth	Está fora do controle do sistema; só se comunica com processos.
Processo	P	P1 SPA Angular, P2 API REST	Todo processo tem ao menos uma entrada e uma saída.
Armazenamento	D	D1 Banco SQLite, D2 Pasta de uploads	Só se conecta a processos (nunca direto a entidade ou a outro armazenamento).
Fluxo de dados	F	F1 credenciais (HTTPS/JSON)	Rotulado com o dado trafegado e, quando relevante, o protocolo.
Fronteira de confiança	TB	TB1 Internet | aplicação	Marca onde o nível de confiança muda; todo fluxo que a cruza merece atenção redobrada.

> **DFD não é fluxograma**
>
> O DFD mostra **por onde os dados passam e onde ficam**, não a sequência de decisões do programa. Não use losangos de decisão, "início/fim" ou setas que representem ordem de execução. Se precisar mostrar a ordem das mensagens de um fluxo, complemente com um diagrama de sequência (opcional).

5.2 Níveis de diagrama exigidos

- **DFD nível 0 (contexto):** o sistema como um único processo, com as entidades externas e os principais fluxos. Já aparece de forma preliminar na Etapa 1.
- **DFD nível 1 (detalhado):** os processos internos, os armazenamentos, todos os fluxos relevantes e as fronteiras de confiança. É sobre ele que os fluxos são recortados.
- **Recorte por fluxo:** para cada fluxo analisado, uma figura destacando apenas os elementos que ele percorre (pode ser um nível 2 ou um destaque do nível 1).

A Figura 2 ilustra o nível de detalhe esperado em um DFD nível 1, usando o sistema fictício "MeuCondomínio" do desafio de aula. **Não é o sistema de vocês**: serve apenas como referência de forma.

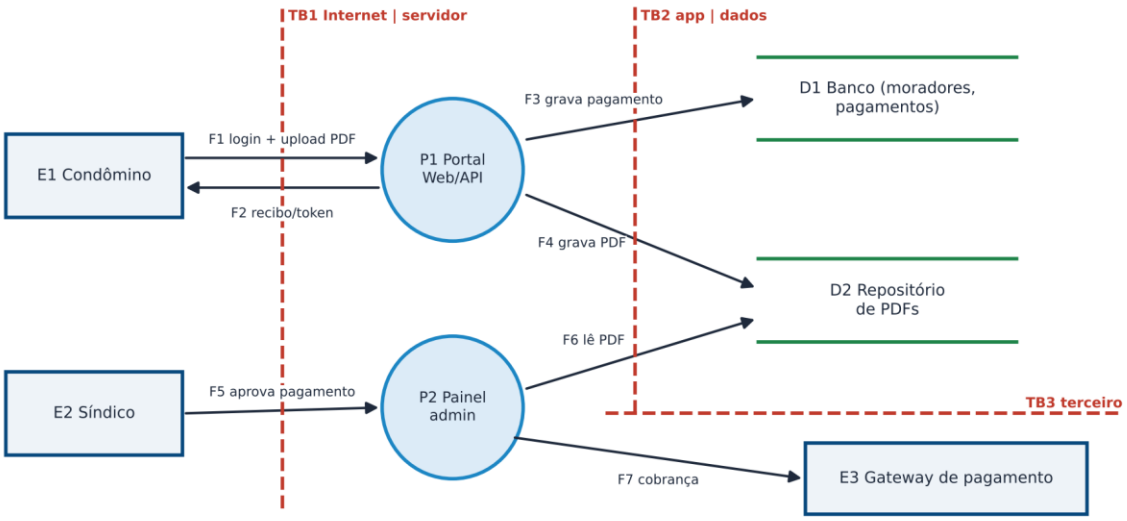


Figura 2. Exemplo de DFD nível 1 com fronteiras de confiança: sistema fictício "MeuCondomínio" (elaborado pelo autor).

5.3 Seleção dos fluxos (mínimo de 4)

Um "fluxo", neste trabalho, é uma **funcionalidade de ponta a ponta** do sistema (por exemplo, "login e uso da sessão"), que normalmente percorre vários elementos do DFD e vários fluxos de dados. A seleção deve obedecer aos critérios:

- **Obrigatório:** pelo menos 1 fluxo de **autenticação e gestão de sessão** (login, emissão e uso do token ou da sessão).
- Pelo menos 1 fluxo que **grave ou exponha dados pessoais** (relação com a LGPD).
- Pelo menos 1 fluxo que envolva **função privilegiada** (administração) **ou integração externa** (serviço de terceiro, componente auxiliar).
- Todos os fluxos escolhidos devem **cruzar ao menos uma fronteira de confiança**.
- Preferencialmente, ao menos 2 fluxos devem conter achados do Trabalho 1, para permitir a comparação entre ameaças confirmadas e plausíveis.

Sugestões de fluxos candidatos (a equipe pode propor outros, justificando):

Cenário A: OWASP Juice Shop	Cenário B: OWASP WebGoat
Login com e-mail e senha, emissão do token e uso nas chamadas à API	Cadastro e login no WebGoat e manutenção da sessão
Login com conta Google (OAuth 2.0)	Registro e consulta do progresso das lições por usuário
Cadastro de usuário e recuperação de senha	Fluxo de redefinição de senha com e-mail entregue no WebWolf
Busca e listagem de produtos	Integração WebGoat e WebWolf (caixa de e-mail, arquivos, página de captura)
Cesta, checkout, endereço, pagamento e registro do pedido	Lições que usam tokens (autenticação baseada em token)
Avaliações de produtos e feedback de clientes	Upload de arquivos (por exemplo, foto de perfil em lições)

Cenário A: OWASP Juice Shop	Cenário B: OWASP WebGoat
Upload de arquivo na página de reclamação	Consultas a dados de funcionários nas lições de banco de dados
Exportação e apagamento de dados pessoais (privacidade)	Reinício de lições e funções administrativas
Área administrativa e notificações por WebSocket	

6. Análise STRIDE de cada fluxo

6.1 Revisão rápida: STRIDE e propriedades violadas

Letra	Categoria	Propriedade violada
S	Spoofing (falsificação de identidade)	Autenticidade
T	Tampering (adulteração)	Integridade
R	Repudiation (repúdio)	Não repúdio
I	Information Disclosure (exposição de informação)	Confidencialidade
D	Denial of Service (negação de serviço)	Disponibilidade
E	Elevation of Privilege (elevação de privilégio)	Autorização

6.2 STRIDE por elemento

Nem toda categoria se aplica a todo elemento. A tabela abaixo é a regra prática da Microsoft (STRIDE-per-element) vista em aula. Ela define o **mínimo** a analisar em cada elemento do fluxo; a equipe pode (e deve) ir além quando houver motivo concreto. Toda célula marcada que não gerar ameaça precisa de uma **justificativa curta** de não aplicabilidade.

Tipo de elemento	S	T	R	I	D	E
Entidade externa (E)	X		X			
Processo (P)	X	X	X	X	X	X
Armazenamento de dados (D)		X	(X)	X	X	
Fluxo de dados (F)		X		X	X	

(X) em Repudiation para armazenamento: aplica-se quando o armazenamento guarda registros de auditoria (logs).

6.3 Passo a passo para cada fluxo

1. Preencha a **Ficha do fluxo** (identificação, elementos percorridos, dados e controles existentes).
2. Observe o fluxo funcionando no laboratório (DevTools/proxy) e registre as requisições que o compõem.

3. Monte a **Matriz STRIDE por elemento** do fluxo, marcando as categorias aplicáveis.
4. Responda ao **Questionário obrigatório** (Seção 7.3).
5. Redija cada ameaça no **formato padrão** (Seção 6.4) e registre-a no **Registro de ameaças**.
6. Atribua as notas **DREAD**, justificando cada uma, e calcule a média.
7. Proponha a **mitigação** e a decisão de tratamento (mitigar, aceitar, transferir ou eliminar).
8. Feche o fluxo com a **conclusão** (ameaça mais grave, risco residual, relação com o Trabalho 1).

6.4 Como redigir uma ameaça (evite ameaças genéricas)

"Pode haver DoS" ou "risco de SQL injection" **não** são ameaças bem descritas. Use a estrutura:

> **Formato padrão da ameaça**
>
> **Um** [agente de ameaça, com sua condição: anônimo, usuário autenticado, administrador malicioso, serviço comprometido] **pode** [ação] **em** [elemento ou fluxo do DFD, com ID] **explorando** [fraqueza ou ausência de controle], **resultando em** [impacto sobre o ativo e sobre o titular de dados].
>
> *Exemplo (sistema fictício):* "Um condômino autenticado pode alterar o identificador do boleto na requisição do fluxo F1, explorando a falta de verificação de propriedade no processo P1, resultando na vinculação do seu comprovante à cobrança de outro morador (fraude contábil)."

6.5 Priorização com DREAD

Cada dimensão recebe nota de 1 (baixo) a 10 (alto); o risco é a **média aritmética** das cinco notas. Escala adotada na disciplina: **0 a 3,9 baixo; 4,0 a 6,9 médio; 7,0 a 10 alto**. Por ser um método subjetivo, **cada nota deve vir acompanhada de uma frase de justificativa**. Equipes que preferirem podem usar a OWASP Risk Rating Methodology, desde que apliquem o mesmo método a todas as ameaças.

Dimensão	Pergunta orientadora
Damage (dano)	Qual o estrago se a ameaça se concretizar (dados, dinheiro, reputação, titulares)?
Reproducibility (reprodutibilidade)	Com que facilidade o cenário pode ser repetido?
Exploitability (explorabilidade)	Quanto conhecimento, acesso e ferramenta o agente precisa?
Affected users (usuários afetados)	Quantos usuários ou titulares são atingidos?
Discoverability (descoberta)	Com que facilidade a fraqueza é descoberta?

6.6 Mitigações e decisão de tratamento

- A mitigação deve ser **específica e verificável** ("verificar no servidor que o recurso pertence ao usuário da sessão em toda requisição"), e não vaga ("usar segurança", "criptografar tudo").
- Relacione cada mitigação a uma referência: requisito do **OWASP ASVS** (capítulo e número), **CWE**, **OWASP Cheat Sheet** e, quando houver dado pessoal, ao **art. 46 da LGPD**.

- Indique o tipo de controle: preventivo, detectivo ou corretivo; e a camada (aplicação, dados, rede, processo/organização). Esta é a ponte para a Unidade 3.
- Decisão de tratamento: **mitigar**, **aceitar** (com justificativa), **transferir** ou **eliminar** a funcionalidade.
- Status da ameaça: **Confirmada no T1 (V#)**, **Plausível** (não testada) ou **Tratada por controle existente**.

6.7 Volume mínimo esperado

- Por fluxo: no mínimo **6 ameaças**, cobrindo as **seis categorias STRIDE** ao longo do fluxo (ou justificando a ausência de alguma).
- No modelo completo: um **Top 10** consolidado das ameaças de maior risco, com mitigações priorizadas.

7. Template de mapeamento

O template abaixo deve ser repetido para **cada fluxo** analisado (uma seção do capítulo 6 do relatório por fluxo). Uma versão editável acompanha este roteiro: **Template_Mapeamento_Ameacas_T2.docx**. O exemplo parcialmente preenchido está no Apêndice A.

7.1 Ficha do fluxo

Campo	O que registrar
ID e nome do fluxo	Ex.: FX1 Login e uso da sessão
Responsável	Integrante que conduziu a análise (e revisor)
Descrição funcional	3 a 6 linhas: o que o fluxo faz do ponto de vista do usuário
Ator iniciador e gatilho	Quem inicia e o que dispara o fluxo
Pré-condições	Ex.: usuário cadastrado; sessão válida
Resultado esperado	Estado final do sistema e resposta ao usuário
Requisições observadas	Método e rota (ex.: POST /rota) de cada passo, com print do laboratório
Recorte do DFD	Figura com os elementos percorridos e as fronteiras cruzadas

Elementos percorridos

Passo	Origem	Destino	Fluxo (ID)	Dados trafegados	Protocolo / formato	Fronteira
1	E1	P1	F1	e-mail, senha	HTTPS / JSON	TB1
2	P1	D1	F3	consulta do usuário	driver do banco	TB2
...						

Classificação dos dados do fluxo

Dado	Classificação	Onde aparece	Propriedade CID mais crítica
Ex.: senha	Credencial/segredo	Trânsito (F1), repouso (D1, como hash)	Confidencialidade
Ex.: endereço	Dado pessoal (LGPD)	Trânsito, repouso, resposta da API	Confidencialidade

Classes sugeridas: público; interno; dado pessoal; dado pessoal sensível (LGPD, art. 5º, II); credencial ou segredo.

Controles existentes observados

Liste o que já protege o fluxo (por exemplo: TLS, hash de senha, token com expiração, validação de entrada, limites de taxa, logs), indicando como foi constatado (observação no laboratório, código-fonte ou documentação).

7.2 Matriz STRIDE por elemento do fluxo

Uma linha por elemento percorrido. Marque **X** quando houver ameaça registrada (cite o ID), **N/A** com justificativa quando a categoria se aplica ao tipo de elemento mas não ao caso concreto, e deixe em branco quando a categoria não se aplica ao tipo de elemento.

Elemento (ID)	S	T	R	I	D	E
E1 Usuário	T-FX1-01		T-FX1-04			
F1 credenciais		X		X	N/A (justificar)	
P1 API	X	X	X	X	X	X
...						

7.3 Questionário obrigatório por fluxo

Responda a **todas** as perguntas em texto corrido e objetivo, citando os IDs do DFD e das ameaças. Respostas do tipo "sim" ou "não" sem explicação não são aceitas.

Compreensão do fluxo

ID	Pergunta norteadora
Q1	Qual é o objetivo de negócio deste fluxo e por que ele é relevante para a segurança do sistema?
Q2	Quem inicia o fluxo e quais papéis podem executá-lo (anônimo, usuário autenticado, administrador, sistema externo)? O que muda entre eles?
Q3	Quais elementos do DFD o fluxo percorre, em que ordem e por meio de quais protocolos e formatos (HTTP/REST, WebSocket, JSON, consultas ao banco etc.)?

ID	Pergunta norteadora
Q4	Quais fronteiras de confiança o fluxo cruza? O que muda no nível de confiança em cada uma delas?
Q5	Quais dados trafegam e quais são armazenados? Quais são dados pessoais ou pessoais sensíveis (LGPD, art. 5º) e quais são credenciais ou segredos?
Q6	Quais pontos de entrada o fluxo expõe (parâmetros, cabeçalhos, cookies, tokens, arquivos)? A que categoria de superfície de ataque pertencem?
Q7	Quais controles de segurança já existem no fluxo, conforme observado no laboratório e na documentação?

S: Spoofing

ID	Pergunta norteadora
S1	Como cada elemento prova sua identidade ao próximo (usuário para aplicação, aplicação para banco, aplicação para serviço externo)?
S2	Qual credencial ou token é usado? Como é emitido, transportado, validado, renovado e revogado? Expira?
S3	Algum elemento poderia se passar por outro (usuário, serviço, servidor)? Em que condições?

T: Tampering

ID	Pergunta norteadora
T1	Em quais pontos os dados podem ser modificados: no cliente, em trânsito, em processamento ou em repouso?
T2	O servidor revalida tudo o que vem do cliente (identificadores, preços, quantidades, papéis, campos ocultos)?
T3	Existe verificação de integridade (TLS, assinatura, hash, validação de esquema) nos dados e artefatos do fluxo?

R: Repudiation

ID	Pergunta norteadora
R1	Quais ações do fluxo são registradas em log? O registro contém quem, quando, o quê e de onde?
R2	Os registros estão protegidos contra alteração e exclusão, inclusive por um administrador ou por um atacante que comprometa a aplicação?
R3	Um usuário conseguiria negar, de forma plausível, ter realizado uma ação deste fluxo?

I: Information Disclosure

ID	Pergunta norteadora
I1	Que informações aparecem em respostas, mensagens de erro, URLs, logs, cache ou armazenamento e poderiam chegar a quem não deveria?
I2	O fluxo trafega ou guarda mais dados do que o necessário (princípio da necessidade/minimização da LGPD)?
I3	Os dados estão protegidos em trânsito e em repouso de forma adequada à sua classificação?

D: Denial of Service

ID	Pergunta norteadora
D1	Quais recursos o fluxo consome que poderiam ser esgotados (CPU, memória, disco, conexões, cota de terceiros)?
D2	Existem limites de taxa, de tamanho, de tempo ou de quantidade? Onde são aplicados?
D3	O fluxo depende de componentes ou serviços externos cuja indisponibilidade derruba a funcionalidade?

E: Elevation of Privilege

ID	Pergunta norteadora
E1	Onde e como a autorização é verificada? É verificada no servidor, a cada requisição, para cada recurso?
E2	Um usuário poderia acessar recursos de outro usuário ou funções administrativas por meio deste fluxo?
E3	Os processos e contas de serviço envolvidos operam com o menor privilégio necessário?

Fechamento do fluxo (4ª pergunta de Shostack)

ID	Pergunta norteadora
V1	Qual é a ameaça mais grave deste fluxo e por quê? Qual o impacto para o negócio e para os titulares de dados?
V2	Quais ameaças foram confirmadas em laboratório no Trabalho 1 (cite os IDs V1, V2...) e quais permanecem hipotéticas?
V3	Quais premissas, limitações e pontos não analisados existem? O que a equipe revisaria se tivesse mais tempo?

7.4 Registro de ameaças

O registro é dividido em duas partes para caber na página: **identificação** e **tratamento**. O ID segue o padrão **T-FX<n>-<seq>** (ex.: T-FX2-05).

Parte A: identificação

ID	Elemento	STRIDE	Cenário da ameaça (formato padrão)	Propriedade violada	CWE / OWASP Top 10	Status
T-FX1-01	E1 / F1	S	Um ... pode ... em ... explorando ..., resultando em ...	Autenticidade	CWE-xxx / A0x	Plausível

Parte B: tratamento

ID	Controle existente	D	R	E	A	D	Média / risco	Mitigação proposta e referência	Decisão
T-FX1-01	...	6	6	7	5	6	6,0 Médio	... (ASVS x.y.z; Cheat Sheet ...)	Mitigar

Abaixo da Parte B, inclua as justificativas das notas DREAD de cada ameaça (uma linha por dimensão).

7.5 Conclusão do fluxo

- Ameaça mais grave do fluxo e justificativa (resposta à V1).
- Comparação com o Trabalho 1: quais ameaças foram confirmadas e quais o teste não cobriu (V2).
- Risco residual após as mitigações propostas, premissas e limitações (V3).

8. Ferramentas sugeridas para o diagrama

A ferramenta é livre, mas o **arquivo-fonte editável** do modelo deve ser entregue junto com o relatório (por exemplo: .json do Threat Dragon, .tm7 do Microsoft TMT, .drawio, ou o script .py/.yaml no caso de modelo como código).

Ferramenta	Tipo	Plataforma e custo	Pontos fortes para este trabalho
OWASP Threat Dragon (recomendada)	DFD com motor de ameaças	Web (threatdragon.com) e desktop; gratuita, open-source	Mesma ferramenta da prática em aula; sugere ameaças STRIDE por elemento; exporta o modelo em JSON e gera relatório.
Microsoft Threat Modeling Tool	DFD com motor de ameaças	Windows; gratuita	Referência histórica do STRIDE; gera automaticamente a lista de ameaças a partir de templates; arquivo .tm7.
draw.io / diagrams.net	Diagramação livre	Web e desktop; gratuita	Muito flexível para figuras de alta qualidade no relatório; as ameaças são registradas manualmente.
OWASP pytm	Modelo de ameaças como código (Python)	Open-source; requer Python e Graphviz	Gera DFD, diagrama de sequência e relatório a partir do código; versionável no Git, ótimo para quem gosta de automação.
Threagile	Modelo de ameaças como código (YAML)	Open-source; roda em Docker	Aplica regras de risco automaticamente ao modelo em YAML e gera diagramas e relatório.

Ferramenta	Tipo	Plataforma e custo	Pontos fortes para este trabalho
Mermaid / PlantUML	Diagrama a partir de texto	Gratuitas; integram com Markdown e Git	Bons para diagramas de sequência complementares de cada fluxo.
Excalidraw / Miro (plano gratuito)	Quadro colaborativo	Web	Úteis para o rascunho em equipe na aula de 17/10, antes de passar a limpo.

Atenção com a sugestão automática de ameaças

Threat Dragon e Microsoft TMT sugerem ameaças genéricas a partir do tipo de elemento. Elas são um **ponto de partida**, não a resposta: cada ameaça aceita deve ser reescrita no formato padrão, no contexto do sistema de vocês. Copiar sugestões automáticas sem contextualizar será considerado análise incompleta.

9. Frameworks e referências de apoio

Framework	Para que usar neste trabalho
Quatro perguntas de Shostack e Threat Modeling Manifesto (2020)	Estrutura geral do trabalho e valores da modelagem (Seções 1 e 3).
STRIDE / STRIDE por elemento (Microsoft SDL)	Identificação sistemática das ameaças em cada elemento (Seção 6).
DREAD e OWASP Risk Rating Methodology	Priorização das ameaças com critério explícito.
LINDDUN (KU Leuven)	Modelagem de ameaças à privacidade; recomendada como complemento no fluxo que trata dados pessoais (ponte com a LGPD). Opcional.
PASTA (UcedaVélez e Morana, 2015)	Visão centrada em risco de negócio; útil para enriquecer a contextualização e o impacto das ameaças.
Árvores de ataque (Schneier, 1999)	Aprofundar a ameaça mais crítica do modelo, decompondo os caminhos possíveis. Opcional.
MITRE CAPEC	Associar cada ameaça a um padrão de ataque catalogado.
MITRE CWE e OWASP Top 10:2021	Classificar a fraqueza subjacente, mantendo a continuidade com o Trabalho 1.
OWASP ASVS (versão 5.0)	Fonte de requisitos verificáveis para as mitigações.
OWASP Cheat Sheet Series	Threat Modeling Cheat Sheet e Attack Surface Analysis Cheat Sheet (método); demais cheat sheets (mitigações).
ISO/IEC 27005 e NIST SP 800-30	Fundamentação de gestão e avaliação de riscos (ponte com a Unidade 3).
LGPD (Lei 13.709/2018), arts. 5º, 6º e 46 a 49	Classificação de dados pessoais, princípios e dever de segurança.
Elevation of Privilege (cartas, Microsoft) e OWASP Cornucopia	Dinâmicas em formato de jogo de cartas para levantar ameaças em equipe; sugeridas para a aula de 17/10.

10. Estrutura obrigatória do relatório final (28/10)

1. **Capa, resumo e quadro de participação** (integrante, fluxos sob sua responsabilidade, outras tarefas).
2. **Introdução:** objetivo, escopo e organização do documento.
3. **Fundamentação teórica:** versão revisada da Etapa 1.
4. **Contextualização do ambiente:** versão revisada da Etapa 1 (perguntas C1 a C10).
5. **Metodologia:** processo seguido, ferramentas, convenções de IDs, método de priorização, divisão do trabalho.
6. **Modelo do sistema:** DFD nível 0 e nível 1; inventário de elementos (tabela com ID, tipo, descrição, tecnologia); fronteiras de confiança; superfície de ataque.
7. **Análise dos fluxos:** uma seção por fluxo, com o template completo (ficha, matriz, questionário, registro, conclusão).
8. **Visão consolidada:** Top 10 ameaças priorizadas; distribuição das ameaças por categoria STRIDE e por elemento; plano de mitigação priorizado.
9. **Validação e limitações:** comparação com o Trabalho 1, revisão cruzada entre integrantes, premissas e o que ficou fora do escopo.
10. **Conclusão** e **Referências** (ABNT).
11. **Apêndices:** arquivo-fonte do modelo (ou link para o repositório) e prints de apoio.

Formato de entrega: relatório em PDF + arquivo-fonte do modelo, no AVA. Se a equipe usou repositório Git no Trabalho 1, crie a pasta **trabalho2/** no mesmo repositório e informe o link.

11. Apresentação (09/11)

- **Tempo:** até **15 minutos** por equipe, seguidos de perguntas. O tempo será controlado.
- **Todos os integrantes apresentam.** A nota da apresentação é **individual**. Sugere-se que cada integrante apresente o(s) fluxo(s) pelos quais foi responsável.
- **Estrutura sugerida:** contexto do sistema (2 min); DFD nível 1 e fronteiras (3 min); fluxos e principais ameaças (7 min); Top ameaças e mitigações (2 min); lições aprendidas e comparação com o Trabalho 1 (1 min).
- **Comece pelo DFD:** ele é o fio condutor da apresentação.
- **Participação como plateia:** fazer perguntas qualificadas aos outros grupos **também compõe a avaliação**. Cada equipe deve dirigir ao menos uma pergunta a outra equipe; o professor registra as participações individuais.

Critérios observados na nota individual

Critério	O que se espera
Domínio do conteúdo	Explica com segurança a sua parte e entende o modelo como um todo (qualquer integrante pode ser questionado sobre qualquer fluxo).

Critério	O que se espera
Precisão técnica	Ameaças concretas, categorias STRIDE corretas, priorização e mitigações coerentes.
Clareza e uso do DFD	Comunicação objetiva, apoiada no diagrama e nos IDs.
Gestão do tempo	Cumpre o limite de 15 minutos da equipe, com divisão equilibrada.
Respostas às perguntas	Responde com fundamento às perguntas da turma e do professor.
Participação nas apresentações dos colegas	Faz perguntas pertinentes e construtivas aos outros grupos.

12. Cronograma

Data	Atividade	Marco
17/10	Leitura do roteiro; revisão do relatório do Trabalho 1; subir novamente o laboratório.	Preparação
17/10	Aula de reposição: pesquisa, fundamentação, contextualização (C1 a C10), DFD nível 0 preliminar, fluxos candidatos.	Etapa 1 em aula
Seg., 19/10, 23h59	Entrega parcial 1 no AVA (3 a 5 páginas; valida a presença da aula de 17/10).	ENTREGA 1
20 a 22/10	DFD nível 1 completo; inventário de elementos; fichas dos fluxos; observação dos fluxos no laboratório.	Modelo do sistema
23 a 26/10	STRIDE por elemento; questionário; registro de ameaças; DREAD; mitigações.	Registro de ameaças
27/10	Revisão cruzada entre integrantes, Top 10, comparação com o Trabalho 1, checklist.	Validação
28/10, 23h59	Entrega do relatório final + arquivo-fonte do modelo no AVA.	ENTREGA 2 (Nota 1)
29/10 a 08/11	Slides, divisão das falas, ensaio cronometrado.	Slides prontos
09/11	Apresentações em aula (até 15 min por equipe) e perguntas entre equipes.	ENTREGA 3 (Nota 2)

15. Referências de apoio

- SHOSTACK, Adam. **Threat Modeling: Designing for Security**. Indianapolis: Wiley, 2014.
- HOWARD, Michael; LIPNER, Steve. **The Security Development Lifecycle**. Redmond: Microsoft Press, 2006.
- UCEDAVÉLEZ, Tony; MORANA, Marco M. **Risk Centric Threat Modeling: Process for Attack Simulation and Threat Analysis**. Hoboken: Wiley, 2015.
- SCHNEIER, Bruce. Attack Trees. **Dr. Dobb's Journal**, v. 24, n. 12, 1999.

- JANCA, Tanya. **Alice and Bob Learn Application Security**. Indianapolis: Wiley, 2020.
- THREAT MODELING MANIFESTO. Disponível em: threatmodelingmanifesto.org.
- OWASP FOUNDATION. Threat Modeling Cheat Sheet; Attack Surface Analysis Cheat Sheet. Disponível em: cheatsheetseries.owasp.org.
- OWASP FOUNDATION. OWASP Threat Dragon; OWASP pytm; OWASP Risk Rating Methodology; OWASP ASVS. Disponível em: owasp.org.
- MICROSOFT. Microsoft Threat Modeling Tool: threats (STRIDE). Disponível em: learn.microsoft.com.
- KU LEUVEN (DistriNet). LINDDUN: privacy threat modeling framework. Disponível em: linddun.org.
- MITRE. CAPEC e CWE. Disponível em: capec.mitre.org e cwe.mitre.org.
- NIST. **SP 800-30 Rev. 1**: Guide for Conducting Risk Assessments. Gaithersburg: NIST, 2012.
- ABNT. **NBR ISO/IEC 27005**: gestão de riscos de segurança da informação. Rio de Janeiro: ABNT (consulte a edição vigente).
- BRASIL. Lei nº 13.709, de 14 de agosto de 2018 (LGPD).
- Documentação: OWASP Juice Shop (help.owasp-juice.shop) e OWASP WebGoat (github.com/WebGoat/WebGoat).

Apêndice A: exemplo parcialmente preenchido

Exemplo com o sistema **fictício** "MeuCondomínio" (Figura 2), fluxo "Envio de comprovante de pagamento". Mostra o nível de detalhe esperado; **não** é modelo a ser copiado para o sistema de vocês.

Ficha do fluxo (resumo)

Campo	Conteúdo
ID e nome	FX1 Envio de comprovante de pagamento
Descrição funcional	O condômino autentica no portal, seleciona um boleto em aberto e envia o comprovante em PDF. O portal grava o arquivo no repositório (D2) e registra o pagamento como "em análise" no banco (D1). O síndico depois aprova pelo painel (P2).
Ator iniciador	E1 Condômino autenticado
Elementos percorridos	E1, F1, P1, F3, D1, F4, D2, F2
Fronteiras cruzadas	TB1 (Internet | servidor) e TB2 (aplicação | dados)
Dados	Credenciais e token (credencial); nome, unidade, CPF no comprovante (dado pessoal); valor e identificador do boleto (interno)
Controles existentes	HTTPS no portal; login com e-mail e senha; tipo de arquivo verificado apenas pela extensão

Matriz STRIDE por elemento

Elemento	S	T	R	I	D	E
E1 Condômino	01		03			
F1 login + upload		02		N/A: HTTPS	N/A: ver P1	
P1 Portal Web/API	N/A: ver E1	02	03		05	06
F4 grava PDF		N/A: rede interna		N/A: rede interna		
D2 Repositório de PDFs		N/A (*)		04	05	

Números = sequencial da ameaça (T-FX1-nn). (*) Em um trabalho real, cada N/A precisa de justificativa por escrito abaixo da matriz.

Registro de ameaças: parte A (identificação)

ID	Elem.	STRIDE	Cenário da ameaça	Propriedade	CWE / OWASP	Status
T-FX1-01	E1	S	Um atacante com credenciais vazadas de um condômino pode entrar no portal (P1) e enviar comprovantes em nome dele, explorando a autenticação apenas por senha, resultando em fraude atribuída à vítima.	Autenticidade	CWE-287 / A07	Plausível

ID	Elem.	STRIDE	Cenário da ameaça	Propriedade	CWE / OWASP	Status
T-FX1-02	F1, P1	T	Um condômino autenticado pode alterar o identificador do boleto na requisição F1, explorando a falta de verificação de propriedade em P1, resultando na vinculação do comprovante à cobrança de outro morador.	Integridade	CWE-639 / A01	Plausível
T-FX1-03	E1, P1	R	Um condômino pode negar ter enviado um comprovante adulterado, pois P1 não registra quem enviou, quando, de qual origem e o hash do arquivo, impedindo a apuração.	Não repúdio	CWE-778 / A09	Plausível
T-FX1-04	D2	I	Um usuário anônimo pode obter comprovantes de terceiros (com CPF) acessando o repositório D2 por endereço previsível, explorando a ausência de autorização no acesso aos arquivos, resultando em vazamento de dados pessoais.	Confidencialidade	CWE-552 / A01	Plausível
T-FX1-05	P1, D2	D	Um usuário autenticado pode enviar arquivos muito grandes em sequência, explorando a falta de limites de tamanho e de quota, resultando no esgotamento do disco de D2 e na indisponibilidade do portal.	Disponibilidade	CWE-400 / A04	Plausível
T-FX1-06	P1	E	Um condômino pode incluir um campo de perfil na requisição de atualização e obter funções do síndico, explorando a atribuição automática de atributos enviados pelo cliente em P1.	Autorização	CWE-915 / A01	Plausível

Registro de ameaças: parte B (tratamento)

ID	D	R	E	A	D	Média	Mitigação proposta	Decisão
T-FX1-01	6	6	7	5	6	6,0 Médio	MFA opcional ao condômino e obrigatório ao síndico; bloqueio progressivo de tentativas; alerta de login em novo dispositivo (Cheat Sheets Authentication e MFA).	Mitigar
T-FX1-02	8	9	8	4	7	7,2 Alto	Em P1, verificar a cada requisição que o boleto pertence ao usuário da sessão; nunca confiar no identificador vindo do cliente (Authorization Cheat Sheet).	Mitigar
T-FX1-03	5	8	7	3	6	5,8 Médio	Trilha de auditoria centralizada e protegida contra alteração, com usuário, data/hora, origem e hash do arquivo (Logging Cheat Sheet).	Mitigar
T-FX1-04	9	9	8	9	7	8,4 Alto	Servir arquivos somente via P1 com autorização por requisição; links temporários assinados; nomes aleatórios; criptografia em repouso (LGPD, art. 46).	Mitigar
T-FX1-05	6	9	9	7	8	7,8 Alto	Limite de tamanho por arquivo, quota por usuário, limitação de taxa e monitoramento de disco (File Upload Cheat Sheet).	Mitigar
T-FX1-06	9	7	6	5	5	6,4 Médio	Lista explícita de campos aceitos (allowlist) e papel definido apenas no servidor (Mass Assignment Cheat Sheet).	Mitigar

Exemplo de justificativa DREAD (T-FX1-04): Damage 9, expõe CPF e dados financeiros de todos os moradores; Reproducibility 9, basta repetir o acesso; Exploitability 8, não exige autenticação nem ferramenta especial; Affected users 9, atinge todo o condomínio; Discoverability 7, os endereços aparecem no próprio navegador do usuário.

Conclusão do fluxo (resumo)

A ameaça mais grave é a T-FX1-04 (8,4), pois combina facilidade de exploração com exposição de dados pessoais de todos os titulares, com reflexos diretos na LGPD. As mitigações de T-FX1-02 e T-FX1-04 são prioritárias. Premissa adotada: a rede entre P1 e D2 é interna e controlada; se não for, F4 passa a exigir análise de Tampering e Information Disclosure.